

POLITIQUE DE SECURITE

Projet CYNA - Infrastructure SR/CYBER

Champ	Valeur
Projet	CYNA - Cybersecurity SaaS (EDR / XDR / SOC)
Document	Politique de securite de l'information
Perimetre	Infrastructure virtualisee, reseau, serveurs, Wazuh, postes et sauvegardes
Format attendu	docs/security-policy.pdf
Redacteur principal	Damien Craciun - Securite
Contributeurs	Adam Boudaoud - Infrastructure Viktor Sormez - DevOps/Wazuh Thibault Lascombes - Equipements utilisateurs

Ce document presente les regles de securite appliquees ou recommandees pour l'infrastructure CYNA.

1. Objectif de la politique de securite

Cette politique de securite a pour objectif de definir les principes, les regles et les bonnes pratiques appliquees a l'infrastructure CYNA. Elle vise a proteger les services critiques, limiter les risques d'intrusion, assurer la disponibilite des ressources et garantir une meilleure tracabilite des evenements de securite.

Le projet CYNA repose sur une architecture virtualisee et segmentee. La securite doit donc etre integree des la conception afin de reduire la surface d'attaque, controler les acces et detecter rapidement les comportements anormaux.

2. Perimetre concerne

Cette politique s'applique aux composants suivants :

- hyperviseur Proxmox et machines virtuelles du projet ;
- pare-feu OPNsense et regles de filtrage inter-VLAN ;
- serveurs Windows : DC01, DC02 et Veeam ;
- serveurs Linux : Web, Web2, HAProxy-DMZ, Syslog-GVA et Wazuh ;
- postes utilisateurs et acces aux ressources internes ;
- outils de supervision, de centralisation des logs et de sauvegarde ;
- scripts Terraform, Ansible et documentation technique stockes dans le repository Git.

3. Principes de securite retenus

Principe	Application dans CYNA
Moindre privilege	Chaque utilisateur, service ou machine ne dispose que des droits necessaires a son role.
Segmentation reseau	Les flux sont separes par VLAN : clients, serveurs, DMZ, management et sites distants.
Defense en profondeur	La securite repose sur plusieurs niveaux : pare-feu, durcissement, supervision, journalisation et sauvegardes.
Traçabilité	Les evenements importants sont collectes et analyses via Wazuh et Syslog.
Durcissement	Les services inutiles sont limites, les acces sensibles sont restreints et les configurations sont surveillees.
Reproductibilite	Les configurations techniques sont documentees et, lorsque possible, automatisees avec Ansible ou Terraform.

4. Controle des acces et gestion des identites

Les acces administratifs doivent etre limites aux personnes autorisees. Les comptes administrateurs sont reserves aux actions d'exploitation et ne doivent pas etre utilises pour des usages quotidiens. Les comptes de service doivent etre dedies a un usage precis et documente.

- application du principe du moindre privilege ;
- utilisation de comptes nominatifs lorsque cela est possible ;
- separation entre comptes utilisateurs, comptes administrateurs et comptes de service ;
- restriction des acces d'administration au VLAN Management ;
- surveillance des connexions reussies, echouees et des modifications de comptes ;
- renforcement des politiques de mot de passe et des parametres de verrouillage de compte.

5. Segmentation reseau et filtrage des flux

L'infrastructure CYNA est separee en plusieurs zones reseau afin de limiter les mouvements lateraux et controler les communications. Les flux non necessaires sont bloques par default. Les services exposes ou semi-exposes sont places en DMZ, tandis que les serveurs internes restent isolés dans les VLAN serveurs.

Zone	Regles principales
VLAN Clients	Postes utilisateurs, acces Internet sortant filtre.
VLAN Serveurs	Services internes critiques : AD, Wazuh, Syslog, sauvegardes.
DMZ	Services web, reverse proxy, HAProxy et composants exposes.
Management	Administration de Proxmox, OPNsense et serveurs. Acces reserve aux administrateurs.
Inter-sites / Azure	Flux chiffrés via VPN/IPSec et autorises selon les besoins.

6. Securite des serveurs et durcissement systeme

Les serveurs Windows et Linux doivent etre durcis afin de reduire leur surface d'attaque. Les resultats SCA Wazuh servent de base pour identifier les ecart de configuration et prioriser les corrections.

- desactivation ou limitation des services inutiles ;
- mises a jour systeme et securite regulieres ;
- configuration securisee de SSH sur les serveurs Linux ;
- restriction de l'administration distante aux reseau autorises ;
- verification des permissions sur les fichiers sensibles ;
- durcissement des politiques Windows sur DC01, DC02 et Veeam ;
- suivi des scores SCA Wazuh et correction progressive des controles echoués.

7. Journalisation, supervision et SIEM Wazuh

Wazuh est utilise comme solution de supervision securite afin de collecter, corréler et analyser les evenements provenant des machines critiques. Les agents Wazuh doivent rester actifs sur les serveurs et les postes identifiés comme sensibles.

Element	Regle appliquee
Agents Wazuh	Deployer les agents sur DC01, DC02, Web, Web2, HAProxy-DMZ, Syslog-GVA et Veeam.
Alertes securite	Surveiller les alertes de brute force SSH, User-Agent suspect, injection SQL et modifications de comptes.
Syslog	Centraliser les journaux systeme et reseau sur Syslog-GVA lorsque cela est possible.
SCA	Evaluer le niveau de durcissement des machines avec les benchmarks CIS.
Revue	Consulter regulierement les alertes et documenter les anomalies importantes.

8. Sauvegarde, restauration et continuité

Les sauvegardes sont un point critique de l'infrastructure. Le serveur Veeam et les ressources associees doivent etre proteges contre les acces non autorises, car ils sont essentiels pour la reprise d'activite en cas d'incident.

- limiter les acces au serveur Veeam aux administrateurs autorises ;
- surveiller les connexions et evenements sensibles sur Veeam ;
- documenter les procedures de sauvegarde et de restauration ;
- tester regulierement la restauration d'une machine ou d'un service ;
- isoler les sauvegardes des zones exposees comme la DMZ.

9. Gestion des incidents de securite

En cas de detection d'un evenement de securite, une procedure de reponse doit etre appliquee afin de limiter l'impact, identifier la cause et remettre le service en production de maniere controlee.

Etape	Action
1. Detection	Identification de l'alerte dans Wazuh, Syslog ou les journaux systeme.
2. Qualification	Analyse du niveau de criticite, de la machine concernee et du type d'evenement.
3. Confinement	Isolation de la machine ou restriction temporaire des flux si necessaire.
4. Correction	Application de la correction technique : regle firewall, hardening, compte, service, mise a jour.
5. Verification	Contrôle des logs, tests de fonctionnement et absence de nouvelle alerte critique.
6. Documentation	Ajout de l'incident, de la preuve et de la correction dans la documentation du projet.

10. Responsabilites

Membre	Responsabilites
Adam Boudaoud	Infrastructure informatique : Proxmox, OPNsense, VLAN, routage, segmentation et disponibilite reseau.
Viktor Sormez	DevOps : Terraform, Ansible, deploiement, automatisation, supervision Wazuh et preuves techniques.
Damien Craciun	Securite : politique de securite, analyse des risques, alertes Wazuh, tests et durcissement.
Thibault Lascombes	Administration des equipements utilisateurs : postes, acces internes, Veeam et ressources utilisateurs.

11. Actions prioritaires de securisation

ID	Action corrective	Priorite
SEC-001	Restreindre SSH au VLAN Management et limiter les tentatives de connexion.	Haute
SEC-002	Renforcer la configuration Nginx/HAProxy et surveiller les requetes applicatives suspectes.	Haute
SEC-003	Surveiller les modifications de comptes locaux sur les serveurs critiques.	Moyenne
SEC-004	Corriger progressivement les controles SCA echoues afin de se rapprocher de l'objectif de 70 %.	Moyenne
SEC-005	Durcir les politiques de mot de passe et de verrouillage sur les serveurs Windows.	Haute

12. Conclusion

Cette politique de securite formalise les principales regles de protection de l'infrastructure CYNA. Elle s'appuie sur la segmentation reseau, le controle des acces, le durcissement systeme, la supervision Wazuh, la centralisation des logs et les sauvegardes.

Les controles SCA et les alertes de detection Wazuh permettent d'identifier les points a ameliorer et de suivre l'evolution de la posture de securite. Cette politique doit etre revue et mise a jour au fur et a mesure des corrections appliquees, des nouveaux services deployes et des retours issus des tests de securite.